〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.28(수)

■ 활동 날짜 및 참여 조원

· 날짜: 2026-10-28(수), 개별 작업 + Notion 작업 보고서 공유

· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

■ 오늘의 목표

· AI-XDR R1 승인 경로(PR #13~#16)와 운영 DB 마이그레이션을 안전하게 반영

· 담당 탐지 룰(R2·R7·R8·R9·R10·R11·R12)의 실사용자 기준 E2E 검증을 이어감

· pfSense XDR 차단 피드 반영 주기를 실사용 가능한 수준(5분)으로 단축

· 밴드 활동일지(10/20~10/23) 누락분 보완 제출

■ 조원별 활동 내역

▶ 진혜정 (자동화·n8n·상황판)

· 팀 GitHub 저장소(stulss/nexus-work)를 별도 세션으로 포크·클론해 ZAP 보안 스캔 알림 3건을 조사 — 세션 쿠키 설정은 이미 올바르게 구성돼 있어 코드 수정 없이 종료

· 담당 6개 룰 중 R2(직접 프롬프트 인젝션)·R9(관리자 경로 접근 거부)·R10(기밀 문서 접근 거부)·R11(AI Tool 반복 거부)·R12(간접 콘텐츠 유발 Tool 거부) 5개를 jinhj·test 계정으로 직접 조작해 Graylog→n8n→/events→/process→assessment 전체 파이프라인까지 확인(전부 PASS)

· R10에서 Graylog 이벤트 정의 쿼리의 경로 와일드카드(path:\/confidential\/*)가 기밀 문서함 "목록" 페이지는 매치하지 못하고 "상세" 페이지만 매치하는 버그를 발견·재현해 확정, 김태빈에게 전달

· R7(심야 로그인 성공)은 KST 00:00~05:00 조건이라 당일 검증 불가 — 서버 시계 조작 없이 심야 시간대로 보류

· 밴드 활동일지(10/20~10/23) 제출본에서 비어 있던 김태빈 섹션을 보완 — 노션 MCP로 접근 안 되는 그의 개인 워크스페이스(Aleph-과제)를 크롬으로 직접 열어 4일치 원문 확보, 4개 PDF 전부 재발행

▶ 홍주형 (웹·DB 하드닝)

· .env에 XDR_AUTO_MIN_CONFIDENCE=0.80 추가 반영, PR #13(R1 승인 조건에서 recommended_actions==〔"review"〕 요건 제거, 신규 POST /internal/api/v1/ai-xdr/decision 멱등 처리) 코드 검토 — 다만 live 모드에서는 /decision이 rule_not_allowed로 거절돼 R1 승인이 실제 차단으로 이어지지 않는 것을 발견, 의도인지 팀 확인 필요로 남김

· 운영 DB 마이그레이션(scripts/migrate_security_ai.py) 적용 — dry-run→보안 4개 테이블 백업→적용 순서로 진행, security_xdr_assessments에 auto_allowed·approval_allowed 컬럼 추가. 기존 PENDING 7건은 승인 대상 조건에 안 맞아 approval_allowed=0으로 남음

· PR #15(외부 티켓 ID를 이벤트 payload에 항상 보존)·#16(보호 IP 목록 PROTECTED_BLOCK_IPS 통합, 모든 차단 경로에서 보호 IP 차단 거부) 재검토, 전체 테스트 203개 중 202개 통과·1개 실패(원인: 마이그레이션을 운영 DB에만 적용해 테스트 DB 스키마가 안 맞음 — 코드 문제 아님)

· HTTPS 전환 방안 정리(pfSense HAProxy에서 TLS 종료, 포털은 접속 확인 후 COOKIE_SECURE=1·ProxyFix 적용) — 인증서 종류 미정으로 실제 변경은 보류

▶ 이시헌 (네트워크)

· 포털→pfSense 간 XDR 차단 피드 체인(PULL 방식: pfSense가 주기적으로 포털 피드를 긁어옴)을 테스트 IP로 전체 검증 — 등록→피드 노출→pfSense 수동 반영까지 정상 동작 확인

· pfSense GUI 기본값인 반영 주기(1일)가 실효성이 없어, 내부 함수 process_alias_urltable(forceupdate=true)로 룰셋 전체 재적용 없이 테이블만 즉시 교체하는 스크립트를 만들어 Cron으로 5분 주기 등록(다른 설정은 변경하지 않아 롤백 가능)

· 두 번째 테스트 IP를 등록한 뒤 아무 조작 없이 5분 대기 — 사람 개입 없이 Cron만으로 pfSense 테이블에 자동 반영되는 것을 확인(완전 자동 검증 성공)

▶ 김태빈 (탐지)

· R1 최종 E2E를 승인 dry-run까지 확인 — Assessment는 APPROVED, response.reason=dry_run, Ticket response 기록과 pending plan 후처리까지 완료

· Ticket DB(.15)와 AI-XDR DB(.14)는 분리 유지로 정리하기로 결론 — 외부 Ticket ID를 correlation/display 기준으로 쓰고, .14에 Ticket row가 없어 incident_ticket_id=NULL인 상태를 정상으로 처리

· blocked-ips API의 CRUD/token 테스트 오류를 수정하고 보호 IP 차단·feed 제외를 적용, 관련 테스트 175개 통과·.14 반영 완료

· Published v3에 AI-XDR 평가 후 Discord 분기 구성 — ticket_ids[]로 Ticket을 조회해 평가 정보와 결합, xdr_discord_enabled만 gate로 사용

· Kali(.77)의 반복 404로 Graylog R8 탐지·n8n 전달을 확인, AI-XDR 3분 집계에서 processed=1 확인(3분 스케줄 Active, 처리 대상 없으면 processed=0)

· Discord 평가 메시지 구성과 synthetic 단건 전송은 확인했으나 운영 후속 경로의 실제 전송은 gate가 닫혀 있어 발생하지 않음, 실제 IP 차단·계정 잠금도 없었음

■ 조원별 의견 및 제안 사항

· 홍주형: 팀원이 전달한 명령을 그대로 실행하지 않고 인자·영향 범위부터 코드로 확인한 덕분에 운영 마이그레이션 실수를 막을 수 있었음 — 다음부터는 마이그레이션을 테스트 DB에 먼저 적용해 테스트를 통과시킨 뒤 운영에 적용하는 순서를 지키기로

· 이시헌: pfSense GUI가 지원하지 않는 주기는 내부 함수를 직접 호출하는 스크립트로 우회할 수 있다는 걸 확인 — 다만 공식 GUI 경로가 아니므로 변경 범위를 좁게 유지하는 게 안전하다는 데 동의

· 김태빈: Ticket DB 분리를 "문제"가 아니라 "정상 상태"로 재정의하고 외부 Ticket ID 기준으로 상관관계를 맞추는 방향이, 당장 인프라를 건드리지 않고도 서비스를 안정시키는 더 현실적인 선택이었음

■ 회의 결과 및 결정 사항

1. R1 승인 경로는 dry-run에서는 정상 동작하나, live 모드에서 실제 차단으로 이어지지 않는 구조(/decision이 rule_not_allowed로 거절)가 의도인지 팀 전체 확인 필요

2. Ticket DB(.15)·AI-XDR DB(.14) 분리는 되돌리지 않고 외부 Ticket ID 기준 상관관계로 유지하기로 확

정

3. R10 Graylog 쿼리 버그(목록 페이지 경로 미매치)는 김태빈이 Graylog 이벤트 정의에서 직접 수정하기로 함

4. pfSense XDR 차단 피드는 5분 주기 자동 반영 체계로 확정, GUI 설정은 변경하지 않음

■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황

- R1 승인 dry-run, R8 자동 피드 반영(5분 주기), R2·R9·R10·R11·R12 E2E 전부 확인됨
- blocked-ips API·보호 IP 목록·Discord 평가 분기까지 안전 장치(gate) 기준으로 구현 완료
- 밴드 활동일지 10/20~10/23 누락분 보완 제출

· 어려운 점

1. 운영 DB에만 마이그레이션을 적용해 테스트 1건이 실패 — 테스트/운영 스키마 적용 순서를 지키지 않은 데서 비롯됨
2. live 모드에서 R1 승인이 실제 차단으로 이어지지 않는 구조적 문제가 아직 팀 확정 전
3. R10 Graylog 쿼리 버그, R7 심야 조건 등 아직 닫히지 않은 항목이 남아 있음

■ 향후 활동 계획 및 역할 분담

· nexus_test DB에 마이그레이션 적용 후 전체 테스트 재실행, Flask를 PR #15·#16 반영 코드로 재시작(홍주형)

· live 모드 R1 승인→실제 차단 연결 여부 팀 확정, 기존 PENDING 7건 처리 방침 결정(전체)

· R10 Graylog 이벤트 정의 쿼리 수정(김태빈)

· Discord 운영 경로 통제된 단건 수신 검증, pfSense XDR_BLOCKED_IPS 외부 관리 접근 제한(김태빈)

· 심야 시간대(00:00~05:00 KST)에 R7 재검증(진혜정)

· 포털 재접속 가능 상태를 활용해 kali-attack-checklist.md 기반 IDOR·SSRF·세션 쿠키 변조·간접 인젝션 수동 테스트 재개(진혜정)

■ 증거 자료

· 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/28) 페이지

- 진혜정 - 10/28 작업 / 2026-10-28_회고록(홍주형) / 10/28일 조별과제 보고서(이시헌) / 2026-10-28 작업 기록(김태빈, 개인 워크스페이스)

· 로컬 파일: E2E_검증결과_R2_R7_R9_R10_R11_R12_10-28.md, 4조_활동일지_10-20~10-23.pdf (재발행본)